STORY-010 Security Audit Logging: evidence

STORY-010 works on the demo deployment, with synthetic data; it is not operating in production. Every security-relevant event is now recorded with who, what, when, the result and the caller's address: registration, sign-in (failed attempts with the address tried, never the password), sign-out, MFA steps, every refusal (401 or 403), every successful read of the API by its route, exports, profile updates (field names only), case decisions and overrides, role grants and removals, each deployment, configuration changes between server starts (secrets named, never their values), and freshness and compliance alerts.

The database makes the log write-once: triggers refuse any update, delete or truncate, every entry carries a retain-until date seven years after it was written, and SSNs, passwords, codes and tokens are removed before anything is written. Staff search it on a Security Audit Log page by date, user, event, area and result.

Screens 1 to 4 come from an automated run against a local copy of the deployed code, because the demo site has no test case-manager accounts. For screen 4 the run restarted the server with shorter sign-in sessions and a new signing secret. Screens 5 and 6 are the deployed demo site.

Checks

- Demo deployment (scripts/verify-deploy.mjs): the API and the site serve dee820a; all 8 page paths serve the current build; database ok; 16 migrations applied (latest 016_config_state.sql); all 22 protected GET routes answer 401 without a token.
- On the demo deployment, signed in as a synthetic citizen (scripts/verify-live-citizen.mjs): all 13 staff GET routes answer 403, no staff links show (the audit log included), and the audit page tells the citizen it is for case managers only.
- UI run (scripts/evidence/story-010.mjs): 10 checks passed, including the configuration change shown without the secret or its fingerprint, and the database refusing to edit or delete a recorded failed sign-in.
- API end to end, local (scripts/e2e): 135 checks passed: access 33, case workflow 26, compliance 30, freshness 16, audit 30. The audit suite also tries UPDATE, DELETE and TRUNCATE directly in the database, and all three are refused.
- Unit tests: 169 passed, including recursive redaction (nested SSNs, passwords, MFA codes and tokens), read-to-route mapping, an ACCESS_DENIED entry written for every refusal, and configuration changes that never write a secret or connection detail to the log. By hand, three local restarts recorded a baseline, then JWT_EXPIRY "(not set) → 1800" with JWT_SECRET named only, then the change back.

Screens

1. Every kind of event, newest first
2. One person's whole trail
3. Every refusal, with what was tried
4. Configuration changes between server starts
5. Demo site after the deploy (citizen view)
6. Demo site: a citizen cannot open the audit log

Notes

- Write-once is enforced by database triggers, which also bind the database owner. A database superuser could still disable a trigger, so production should also ship entries to separate append-only storage (for example AWS CloudWatch Logs or S3 with Object Lock), which comes with the AWS environment (STORY-004).
- A configuration change is found by comparing the settings at each server start with the previous start, so it shows when the change took effect, not who made it: on Render that is in Render's own records, and on AWS CloudTrail would record it.
- The log holds no SSNs, passwords, MFA codes or tokens. It does hold email addresses and caller IP addresses, which an audit trail needs to identify who acted.
- On the demo deployment, requests reach the API through Render's proxies. The server trusts only private-network proxies, so a caller cannot fake their address with a header, but the address recorded there may be a Render edge address rather than the visitor's own. We could not check it, because we have no case-manager account on the demo site.
- Sign-out is recorded, but sign-in tokens remain valid until they expire after an hour; revoking them on sign-out would need a server-side deny list.
- There is no password-change feature yet, so there is no password-change event to record.

- The case-manager role still comes from an email list without verifying that the person owns the address. Every grant is now audited, so a wrongly claimed role is visible, but verified identities are still needed before real data.
- All data shown is synthetic.

1. Every kind of event, newest first

Sam Ortiz, a case manager, opens the Security Audit Log: two server starts with their configuration records, role grants, sign-ups, failed and successful sign-ins, profile and eligibility changes, an application, refusals, a decision with its compliance check, an export and a read of the log itself. The cards confirm write-once, seven-year retention and no personal data, read from the database. The card counts 30 entries and the table 29: the extra one is Sam opening this page, recorded as soon as the table had loaded, because reading the log is itself logged. The run's helper tries to sign each person in before registering them, so each

Security Audit Log

Every sign-in, refusal, data access, change and alert

Dashboard | Profile & Exemptions | Case Management | Compliance | Data Freshness | Audit Log | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Write-once
The database refuses any edit or deletion of an entry.

Kept for 7 years
30 entries, 7 of them refusals or failures.

No personal data
SSNs, passwords, codes and tokens are removed before an entry is written.

From: mm/dd/yyyy | To: mm/dd/yyyy | User: Email | Event: All | Area: All | Result: All | Search | Reset

When	User	Event	Area	Result	Details	From
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Sign-out USER_LOGOUT	auth	Succeeded	—	::1
10/12/2026, 10:12:50 AM	Not signed in	Access denied ACCESS_DENIED	cases	Refused or failed	GET /api/cases → 401	::1
10/12/2026, 10:12:50 AM	sam.ortiz@example.com	Data export DATA_EXPORT	cases	Succeeded	GET /api/cases/export	::1
10/12/2026, 10:12:50 AM	dana.whitfield@example.com	Compliance check COMPLIANCE_CHECK	cases	Succeeded	controls: 7 · decision: Approved · failedControls: none	::1
10/12/2026, 10:12:50 AM	dana.whitfield@example.com	Case status change CASE_STATUS_CHANGE	cases	Succeeded	to: Approved · from: In Review	::1
10/12/2026, 10:12:50 AM	dana.whitfield@example.com	Case status change CASE_STATUS_CHANGE	cases	Succeeded	to: In Review · from: Submitted	::1
10/12/2026, 10:12:50 AM	dana.whitfield@example.com	Case assignment CASE_UPDATE	cases	Succeeded	assignedTo: dana.whitfield@example.com	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Access denied ACCESS_DENIED	compliance	Refused or failed	GET /api/compliance/dashboard → 403	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Access denied ACCESS_DENIED	cases	Refused or failed	GET /api/cases/stats → 403	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Document added CASE_DOCUMENT_UPLOAD	cases	Succeeded	documentType: proof_of_age	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Application CASE_CREATE	cases	Succeeded	status: Submitted · exemptionType: Type A	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Data read DATA_READ	exemptions	Succeeded	GET /api/exemptions	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Eligibility check EXEMPTION_CHECK	exemptions	Succeeded	trigger: profile_update · eligible: true · evaluations: Type A Eligible, Type B Not Eligible, Type C Not Eligible	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Profile update PROFILE_UPDATE	users	Succeeded	fields: phone, address	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Sign-in USER_LOGIN	auth	Succeeded	—	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com (not signed in)	Sign-in USER_LOGIN	auth	Refused or failed	email: jordan.rivera@example.com · reason: VALIDATION_ERROR	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Registration USER_REGISTRATION	auth	Succeeded	role: citizen	::1
10/12/2026, 10:12:48 AM	jordan.rivera@example.com (not signed in)	Sign-in USER_LOGIN	auth	Refused or failed	email: jordan.rivera@example.com · reason: VALIDATION_ERROR	::1
10/12/2026, 10:12:48 AM	sam.ortiz@example.com	Data read DATA_READ	audit	Succeeded	GET /api/audit?action=CASE_STATUS_CHANGE	::1
10/12/2026, 10:12:48 AM	sam.ortiz@example.com	Role granted PERMISSION_GRANT	users	Succeeded	via: CASE_MANAGER_EMAILS at registration · role: case_manager · email: sam.ortiz@example.com	::1
10/12/2026, 10:12:48 AM	sam.ortiz@example.com	Registration USER_REGISTRATION	auth	Succeeded	role: case_manager	::1
10/12/2026, 10:12:47 AM	sam.ortiz@example.com (not signed in)	Sign-in USER_LOGIN	auth	Refused or failed	email: sam.ortiz@example.com · reason: VALIDATION_ERROR	::1
10/12/2026, 10:12:47 AM	dana.whitfield@example.com	Role granted PERMISSION_GRANT	users	Succeeded	via: CASE_MANAGER_EMAILS at registration · role: case_manager · email: dana.whitfield@example.com	::1
10/12/2026, 10:12:47 AM	dana.whitfield@example.com	Registration USER_REGISTRATION	auth	Succeeded	role: case_manager	::1
10/12/2026, 10:12:46 AM	dana.whitfield@example.com (not signed in)	Sign-in USER_LOGIN	auth	Refused or failed	email: dana.whitfield@example.com · reason: VALIDATION_ERROR	::1
10/12/2026, 10:12:41 AM	System	Deployment DEPLOYMENT	system	Succeeded	commit: local · migrationsApplied: none	–
10/12/2026, 10:12:41 AM	System	Configuration change CONFIG_CHANGE	system	Succeeded	via: environment at startup · changed: JWT_EXPIRY, JWT_SECRET · JWT_EXPIRY: (not set) → 1800	–
10/12/2026, 10:12:31 AM	System	Deployment DEPLOYMENT	system	Succeeded	commit: local · migrationsApplied: 001_init_users.sql, 002_init_mfa_devices.sql, 003_init_pipeline_metrics.sql, 004_init_exemptions.sql, 005_init_cases.sql, ...	–
10/12/2026, 10:12:31 AM	System	Configuration change CONFIG_CHANGE	system	Succeeded	via: environment at startup · note: first record; later starts are compared with it · settings: CORS_ORIGIN, JWT_EXPIRY, CASE_MANAGER_EMAILS, DATABASE_SSL, J...	–

29 entries

Previous | Page 1 of 1 | Next

2. One person's whole trail

Searching for Jordan Rivera shows everything, including two refused sign-ins filed under the address that was tried: one before Jordan had an account, and one with a mistyped password. Profile changes list the fields, not their values. No SSN or password appears anywhere.

Security Audit Log
Every sign-in, refusal, data access, change and alert

Dashboard | Profile & Exemptions | Case Management | Compliance | Data Freshness | Audit Log | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Write-once
The database refuses any edit or deletion of an entry.

Kept for 7 years
30 entries, 7 of them refusals or failures.

No personal data
SSNs, passwords, codes and tokens are removed before an entry is written.

From: mm/dd/yyyy | To: mm/dd/yyyy | User: jordan.rivera | Event: All | Area: All | Result: All | Search | Reset

When	User	Event	Area	Result	Details	From
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Sign-out USER_LOGOUT	auth	Succeeded	—	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Access denied ACCESS_DENIED	compliance	Refused or failed	GET /api/compliance/dashboard → 403	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Access denied ACCESS_DENIED	cases	Refused or failed	GET /api/cases/stats → 403	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Document added CASE_DOCUMENT_UPLOAD	cases	Succeeded	documentType: proof_of_age	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Application CASE_CREATE	cases	Succeeded	status: Submitted · exemptionType: Type A	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Data read DATA_READ	exemptions	Succeeded	GET /api/exemptions	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Eligibility check EXEMPTION_CHECK	exemptions	Succeeded	trigger: profile_update · eligible: true · evaluations: Type A Eligible, Type B Not Eligible, Type C Not Eligible	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Profile update PROFILE_UPDATE	users	Succeeded	fields: phone, address	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Sign-in USER_LOGIN	auth	Succeeded	—	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com (not signed in)	Sign-in USER_LOGIN	auth	Refused or failed	email: jordan.rivera@example.com · reason: VALIDATION_ERROR	::1
10/12/2026, 10:12:49 AM	jordan.rivera@example.com	Registration USER_REGISTRATION	auth	Succeeded	role: citizen	::1
10/12/2026, 10:12:48 AM	jordan.rivera@example.com (not signed in)	Sign-in USER_LOGIN	auth	Refused or failed	email: jordan.rivera@example.com · reason: VALIDATION_ERROR	::1

12 entries

Previous | Page 1 of 1 | Next

3. Every refusal, with what was tried

Filtered to Access denied: Jordan was refused two staff pages (403), and a caller who was not signed in was refused the case list (401). Each entry shows the method, the path and the answer.

Security Audit Log
Every sign-in, refusal, data access, change and alert

Dashboard | Profile & Exemptions | Case Management | Compliance | Data Freshness | Audit Log | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Write-once
The database refuses any edit or deletion of an entry.

Kept for 7 years
30 entries, 7 of them refusals or failures.

No personal data
SSNs, passwords, codes and tokens are removed before an entry is written.

From: mm/dd/yyyy | To: mm/dd/yyyy | User: Email | Event: Access denied | Area: All | Result: All | Search | Reset

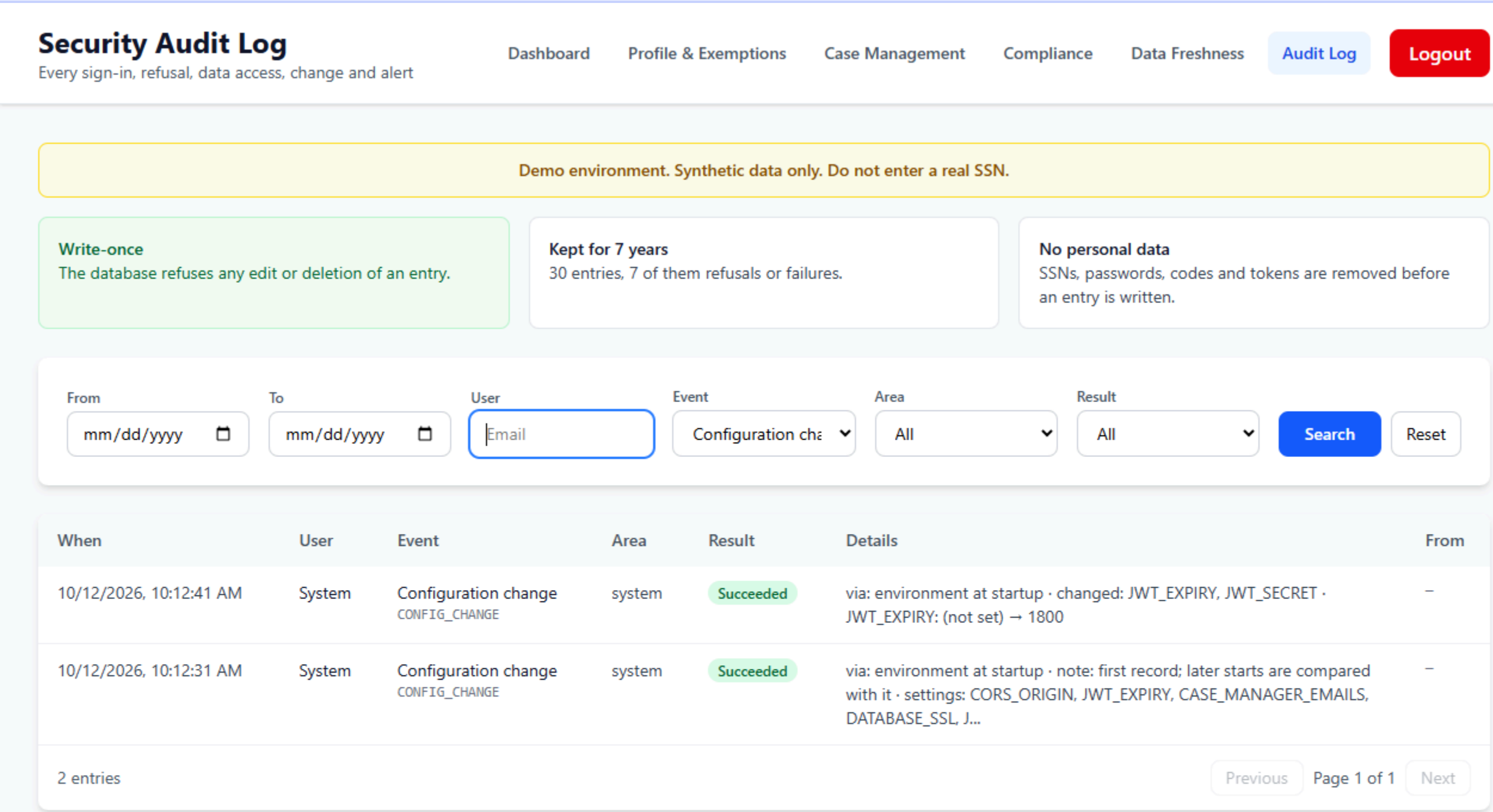
When	User	Event	Area	Result	Details	From
10/12/2026, 10:12:50 AM	Not signed in	Access denied ACCESS_DENIED	cases	Refused or failed	GET /api/cases → 401	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Access denied ACCESS_DENIED	compliance	Refused or failed	GET /api/compliance/dashboard → 403	::1
10/12/2026, 10:12:50 AM	jordan.rivera@example.com	Access denied ACCESS_DENIED	cases	Refused or failed	GET /api/cases/stats → 403	::1

3 entries

Previous | Page 1 of 1 | Next

4. Configuration changes between server starts

Filtered to Configuration change: the first start recorded which settings are tracked; the next start, with sign-in sessions cut to 30 minutes and a new signing secret, recorded both changes. JWT_EXPIRY shows its old and new value; JWT_SECRET is named, never its value or a fingerprint of it.



5. Demo site after the deploy (citizen view)

The deployed demo site lists the security audit log as done, and a citizen sees no staff links.

SSS Modernization
Platform Dashboard

Dashboard | Profile & Exemptions | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Welcome
Deploy Check

Status
Active

Member Since
10/6/2026

Current release
R1

D

Deploy Check

Email
deploy-check@example.com

Status
Active

Notifications

No notifications yet.

Dashboard Overview

Welcome to the SSS Modernization Platform. Release One (R1) is in progress. Working in this demo today: exemption eligibility, case management, compliance validation, data freshness monitoring and a security audit log.

Getting started: check your exemption eligibility and apply from Profile & Exemptions. You can follow each application, and any decision with its reason, from its case page.

Quick Stats

Release Zero
Complete

API Status
✓

Database
✓

Frontend
✓

Release Progress

- ✓ R0: Secure registration and sign-in (hashed passwords and SSNs)
- ✓ R0: Compliance guards (demo-data banner, masked SSN entry)
- ✓ R0: Demo deployment online, with a managed database
- ✓ R1: Profile update with compliance check, and exemption eligibility with reasons
- ✓ R1: Case management: applications, review workflow, timeline, notifications, CSV export
- ✓ R1: Compliance validation: every decision checked against 8 controls, with reviews and an audit log
- ✓ R1: Data freshness: every update timed until it is readable, against a 30-second target
- ✓ R1: Security audit log: every sign-in, refusal, data access and change, write-once
- → R1 (next): Accessibility (Section 508), role-based dashboards

6. Demo site: a citizen cannot open the audit log

Opening /audit directly on the deployed demo site as a citizen shows only that the log is for case managers; the API refuses the same citizen with 403.

